

Nathaniel Abera

August 5th, 2026

Managing Information Security

A1. Stellar Financial Solutions is a financial institution located in San Francisco, California, and it also has operations within the European Union. They provide consumers with digital banking, credit services, and investment management for small businesses and individuals. Two laws relevant to the company are the General Data Protection Regulation (GDPR) and Gramm-Leach-Bliley Act (GLBA).

The GLBA law applies to Stellar Financial Solutions because the company is based in the United States and conducts financial operations which deal with sensitive customer PII, which includes personal information such as Social Security numbers, home addresses, and banking details. The GLBA requires that financial institutions must follow the Safeguards Rule to keep customers' PII safe. Companies such as Stellar Financial Solutions must maintain a written information security program and technical safeguards that protect customer information, and they must include a requirement of encryption and multifactor authentication (Federal Trade Commission, 2021). The case study details that a third-party audit firm performs an annual GLBA assessment of Stellar Financial Solutions' operations.

The GDPR law applies to Stellar Financial Solutions because the company has operations within the European Union which requires all businesses to protect EU residents' personal data and to notify authorities of any personal data breaches within 72 hours of becoming aware of them (European Union, 2016). Since Stellar Financial Solutions stores data of European customers, it must meet these regulations regardless of where the headquarters are located.

To ensure the GLBA law is being enforced, the company should begin to implement policies and procedures that align with the rules. The first is a data encryption policy that requires all of its customers' data to be encrypted not only at rest but also during transmission. As the case study details, the data at rest within the company is the only data being encrypted. However, data being transmitted is not consistently encrypted. This causes sensitive customer PII to be exposed as it

moves through networks. By adding this policy, the company will increase compliance and align with the GLBA Safeguards Rule, as it requires financial institutions such as Stellar Financial Solutions to encrypt customer PII both at rest and in transmission. The second thing the company should implement is adding multifactor authentication (MFA) and an access control policy to all of its systems and also eliminate the usage of shared accounts within the company. Based on the case study, the company does not require users to use multifactor authentication, requires only an eight-character password, and allows for the usage of shared accounts. By using a policy with these new implementations, the company will increase compliance, as the Safeguards Rule requires MFA for anyone accessing customer information.

To ensure the GDPR laws are being enforced, Stellar Financial Solutions must begin implementing these two policies. The first would be a formal breach notification procedure, a step-by-step procedure which explains how security incidents must be handled, detected, and reported within the 72-hour window the GDPR requires. In the phishing incident described in the case study, attackers accessed consumer data for more than two months before the breach was discovered, which means the company would not have met GDPR's notification timeline requirements. This new procedure would allow the company to align with GDPR Article 33, which details that breaches involving EU customer data must be reported to authorities within a 72-hour window. The second policy would be that the company, Stellar Financial Solutions, implements a data protection policy that deploys a data loss prevention (DLP) tool to detect, monitor, and respond to unauthorized data transfers. The case study states that the company has no DLP solution and uses cloud services for shared documents, which adds another uncontrolled path for EU personal data to leave the organization. This policy will ensure that the company is compliant with GDPR Article 32, as it requires technical measures to be in place to ensure the security of personal data, and monitoring data transfers directly implements that requirement.

A2. The first threat identified was the potential risk of ransomware being deployed through unpatched systems. An attacker could deploy this ransomware by taking advantage of Stellar Financial Solutions' unpatched critical systems. The case study states that the change management process omits security reviews and that hosts operated while missing critical operating system patches, both of which are necessary to keep this vulnerability contained.

The likelihood of this attack happening is high (NIST, 2012). Because the business model of the company relies on customer PII to operate, it makes the company a target for this kind of attack. Financial institutions face a multitude of forms of attacks, especially ransomware. As stated in the case study, in the past, Stellar Financial Solutions has already been attacked by ALPHV and the attackers had succeeded, yet the gaps that made them vulnerable were never resolved (no security review in change management, plus legacy systems). Since Stellar Financial Solutions did not look for any signs of lateral movement, C2 traffic, or reconnaissance, the likelihood that another attack would occur and result in adverse impact is even higher, since such activity may already be progressing undetected.

The impact another ransomware attack would have would be high. If a ransomware attack were to be successful, then it would put a stop to core operations of the company and it would encrypt production systems making it hard to resume regular business. In a previous incident, this made the credit services department completely inoperable for more than two weeks. If it were to happen again, it would cause a multitude of consequences, including lost ability to conduct business, interrupted payments, regulatory fines, expensive recovery costs, and reputational harm.

Since both the likelihood and impact are listed as high, the level of risk is also high.

A financial institution such as Stellar Financial Solutions should not operate at such a high risk level, as it not only puts the company at risk but also its users and their information, which could result in heavy fines and implications. Stellar Financial Solutions should begin implementing mitigation procedures by adding mandatory security reviews to change management, deploying continuous monitoring to detect unusual activity, and establishing a formal patch management program that identifies and automatically applies patches when found.

The second threat event identified was unauthorized data exfiltration through compromised user credentials. An attacker would be able to steal financial data as well as other sensitive information such as customer PII by moving data off the network while remaining completely

undetected. The case study identifies several vulnerabilities that enable this: Stellar Financial Solutions did not enforce multifactor authentication (MFA), required passwords of only eight characters, used shared accounts, did not encrypt data in transit, and had no data loss prevention (DLP) solution. These were the same weaknesses that made the company vulnerable to the phishing breach, which exposed customer PII for more than two months.

The likelihood of this happening is high. A phishing attack has already succeeded, and employee credentials were exposed. Because there is no MFA, stolen credentials grant direct access to employee accounts, and the use of shared accounts widens that exposure further. The company also has no solution to detect or block this kind of exfiltration and does not encrypt data in transit, so stolen employee credentials can lead directly to data loss.

The impact this has on the company is high. Because Stellar Financial Solutions handles sensitive customer PII, including Social Security numbers and other financial records, exposure of this data would lead to regulatory violations that carry penalties and fines, mandatory notifications to affected customers, fraud liability, and reputational damage.

Since the likelihood and impact are both rated high, the overall risk level is high.

Since the risk is high, Stellar Financial Solutions should not overlook it and must begin prioritizing mitigation by enforcing new procedures and systems, such as requiring MFA, eliminating shared accounts, strengthening passwords, and deploying a data loss prevention (DLP) solution. These measures will help mitigate the overall risk.

A3. The first recommendation for Stellar Financial Solutions that will strengthen the company's integrity is modifying the existing change management process. The case study details that this process omits security reviews so that change approvals can be streamlined. The company should change this process so that every proposed change must not only undergo a security review but also be approved before it is implemented, with the changes monitored and tracked to see whether they are effective. This not only helps with monitoring what works and what does not, but it also helps with accountability. This modification increases information assurance levels as well because it increases confidence that changes are being conducted under reviews and

approval processes, unlike the misconfigured systems and unpatched software that previously went unnoticed. Adding these implementations will increase the company's confidence in the integrity of its systems and improve overall security as it becomes more of a formal procedure and now it holds an accountability step that analyzes decisions being made before they are made rather than afterwards.

The second recommendation for Stellar Financial Solutions is modifying the company's current information security policy. The case study says that the current policy only covers the basic cybersecurity principles and it was generated using an open-source AI model rather than developed internally by the company. The company should change this by rewriting it based on the NIST Cybersecurity Framework. The company should also assign ownership of the policy to senior leadership and require a formal annual review and update cycle. This modification will increase information assurance levels because it aligns the policy with a recognized framework that protects the company. It also gives the company a strong level of integrity and confidence. By making these changes, the company can ensure that it owns its policy and that the policy aligns with regulatory requirements by conducting proper annual reviews and adding an approval system.

References

European Union. (2016). *Regulation (EU) 2016/679 of the European Parliament and of the Council (General Data Protection Regulation)*. Official Journal of the European Union.
<https://eur-lex.europa.eu/eli/reg/2016/679/oj>

Federal Trade Commission. (2021). *Standards for safeguarding customer information* (16 CFR Part 314). <https://www.ecfr.gov/current/title-16/chapter-I/subchapter-C/part-314>

National Institute of Standards and Technology. (2012). *Guide for conducting risk assessments* (NIST Special Publication 800-30, Rev. 1). U.S. Department of Commerce.
<https://doi.org/10.6028/NIST.SP.800-30r1>